

Directory structure for examples and deployment guide

Introduction

The Certifier has many samples to show how to use it. There are two kinds of examples: the examples for developing applications (in `$CERTIFIER_ROOT/sample_apps/[simple_app, simple_app_for_sev, ...]`) and for developing VM's (in `$CERTIFIER_ROOT/vm_model_tools/example/scenario1`). We refer to each these directories as an environment directory and will refer to each in context as the `$ENVIRONMENT_DIRECTORY`.

One source of confusion is that the `$ENVIRONMENT_DIRECTORY` in the samples combines actions by entities acting if four separate roles in the course of use, one goal of this document is to separate what files and programs are required for each role and which are required in a real deployment.

The four roles are:

- *Application developer*: This entity compiles and builds the application and utilities.
- *Security domain administrator*: This entity generates keys (including the all-important policy key), run-time files and certifier policy and builds deployment packages for the *Certifier service provider* and *User in a deployed environment*.
- *Certifier service provider*: This entity runs the certifier service.
- *User in a deployed environment*: This is the entity that runs the deployed application or VM.

One core concept is that in the deployed environment, the `$ENVIRONMENT_DIRECTORY` acts as an application directory (like `"/Application Support/App..."` on a MAC). For the deployed user, the `$ENVIRONMENT_DIRECTORY` need not be protected; all critical files are signed or protected.

Applications

In the application examples, the *Application developer* compiles the programs in the `$ENVIRONMENT_DIRECTORY` from source files. The developer includes the policy key certificate in the image to bind the policy to the app; this is obtained from the *Security domain administrator*.

The *Security domain administrator* generates key files, certs and policy. These files are stored in `$ENVIRONMENT_DIRECTORY/provisioning` as they are generated. When packaging for distribution to a deployed user or certifier service provider, the *Security domain administrator*

copies the files needed by the certifier service into `$ENVIRONMENT_DIRECTORY/service` and the files needed by the deployed application into its application file directory, typically, `$ENVIRONMENT_DIRECTORY/app_data`.

Most of the application examples, actually have two app directories, one for the app acting as a client for the example secure channel and one acting as the server for the example secure channel. The *Security domain administrator* only packages the application executable (which can be anywhere on the executable path but can reasonably remain in `$ENVIRONMENT_DIRECTORY`) and the *app_data* subdirectory which has some pre-determined files (like the simulated environment keys)¹. During installation and operation, in the style of MAC application configuration, the *app_data* subdirectory will also get things like machine certs, for example, the ARK, ASK, and VCERT certs on sev.

The files deployed to the *User in a deployed environment* never includes the files in the `$ENVIRONMENT_DIRECTORY/provisioning` directory or the `$ENVIRONMENT_DIRECTORY/service` directory; indeed, these have unprotected versions of the private policy key and distributing them completely violates the security promise.

The files in the `$ENVIRONMENT_DIRECTORY/service` are distributed to the *Certifier service provider*; optionally, the `$ENVIRONMENT_DIRECTORY` may contain *simpleserver*, but it need not provided *simpleserver* is installed in some binary directory that can be accessed. The *Certifier service provider* should not receive the `$ENVIRONMENT_DIRECTORY/app_data` or the `$ENVIRONMENT_DIRECTORY/provisioning` directories.

The deployment package for the *User in a deployed environment* can place the executables anywhere but `$ENVIRONMENT_DIRECTORY` is a convenient place. During certification, `$ENVIRONMENT_DIRECTORY/app_data` will contain the policy-store, which protects application specific information in encrypted form.

As a reminder, as deployed, the `$ENVIRONMENT_DIRECTORY` need not be protected, just accessible. For the app samples, the files for all the roles are kept in `$ENVIRONMENT_DIRECTORY`, which may be confusing.

VM's

For VM's, the story is very slightly different; the application files for all the roles are kept in `$ENVIRONMENT_DIRECTORY`. However, the programs that interact with the certifier (*cf_utility*, *keyserver* and *keyclient*) are not particular to the policy key. Basically, there is no *Application developer* role on a VM.

¹ Neither the certifier service nor the deployed user need the certifier utilities, just the app executable.

The *Security domain administrator* is responsible for ensuring all executables in the VM that can use certifier services are measured and that the policy-key cert is also part of the VM measurement. This is often accomplished by putting them in initram. This causes a few minor differences.

1. The executables for the certifier (*cf_utility*, *keyserver* and *keyclient*) are certainly not kept in the `$ENVIRONMENT_DIRECTORY` and the *Security domain administrator* must ensure that the resolved executable paths and *policy-cert* files refer to their measured locations².
2. In the *User in a deployed environment*, the policy-store and the cryptstore (where application keys are stored) are in the `$ENVIRONMENT_DIRECTORY`; the remaining application files are stored in `$ENVIRONMENT_DIRECTORY/cf_data`, this directory will contain copies of the ark, ask and vcert certs, in the sev case, the simulated enclave files, and the endorsement cert (in the tpm case).
3. The `$ENVIRONMENT_DIRECTORY/provisioning` and `$ENVIRONMENT_DIRECTORY/service` directories are exactly as in the application setting and should absolutely not be distributed to the *User in a deployed environment*.
4. As before, the *Security domain administrator*, uses the `$ENVIRONMENT_DIRECTORY/provisioning` directory to store generated keys and policy.
5. Aside from ensuring the certifier executables come from a trusted directory that was part of the measurement, there is no restriction on where the executables can be stored.
6. The VM utilities (*cf_utility*, *keyserver* and *keyclient*) use `$ENVIRONMENT_DIRECTORY/cf_data` for environment storage (for platform certs, for example). The *policy_cert* file should always be retrieved from the secure measured location and thus will likely have an absolute path name.
7. It is most convenient to keep the application storage hierarchy (`$ENVIRONMENT_DIRECTORY` and `$ENVIRONMENT_DIRECTORY/cf_data`, organized as structured).
8. The `$ENVIRONMENT_DIRECTORY` can be anywhere and need not be protected. It should not, for example, be in initram, since it will change.

Final Note

A protected VM can also host an application service, which treats the VM itself as a secure platform that provides isolate, seal, unseal and attest services to applications. The application service can provide application services (see *sample_apps/simple_app_under_app_service*) for individual applications and depends on the OS for isolation among such apps. In this case, there

² Again, neither the end user nor the certifier service provider need the certifier utilities. The deployed user just needs *cf_utility*, *keyserver* and *keyclient*.

will be (at least) three separate `$ENVIRONMENT_DIRECTORY` locations: one for the VM, one for the application service and one for each protected application.